

Rapport d'incidents — SP1 Client léger PHP

Castellane-Auto · Site web PHP/MySQL Période : Janvier — Mars 2026 · Équipe vIndkaizen

1. Méthodologie de suivi

Chaque incident détecté pendant les phases de **développement** et de **recette** a été tracé selon la matrice suivante :

Champ	Description
ID	Identifiant unique (INC-001, INC-002...)
Sévérité	● Critique · ● Majeur · ● Mineur · ● Cosmétique
Symptôme	Ce que l'utilisateur observait
Cause	Diagnostic après analyse du code
Correction	Modification apportée
Statut	✅ Résolu / ⏳ En cours / ➡️ SOON Évolution v2

2. Liste des incidents (client léger PHP)

● INC-001 — Stockage des mots de passe en clair

Sévérité	● Critique (cybersécurité)
Composant	Modele::verifConnexion() + BDD
Symptôme	Les mots de passe étaient stockés en clair dans la table <code>utilisateur</code> . Toute personne ayant accès à la BDD pouvait les lire.
Cause	Méthode <code>verifConnexion()</code> faisait <code>WHERE mdp = :mdp</code> (comparaison directe en clair). Aucun hashage à l'insertion.
Correction	Identification du problème + plan de migration vers <code>password_hash()</code> (bcrypt) + <code>password_verify()</code> documentée. Évolution prévue v2.
Statut	➡️ SOON Évolution v2 documentée

● INC-003 — Rôle utilisateur codé en dur

Sévérité	● Majeur
Composant	index.php
Symptôme	Après connexion admin, <code>\$_SESSION['role']</code> était assigné à la valeur littérale <code>'admin'</code> , et non récupéré depuis la BDD.
Cause	Mauvaise pratique de codage (constante magique).
Correction	Modifié pour utiliser <code>\$user['role']</code> issu directement de la table <code>utilisateur</code> . Plus de hardcoding.
Statut	✅ Résolu

● INC-004 — Déconnexion vulnérable au CSRF

Sévérité	● Majeur
Composant	index.php + vue/entete.php
Symptôme	La déconnexion était déclenchée par une simple URL GET <code>?page=9</code> . Un attaquant pouvait forcer la déconnexion d'un utilisateur connecté via <code></code> .
Cause	Utilisation de GET pour une action mutante (<code>session_destroy</code>).
Correction	Migration vers un formulaire POST : <code><form><button name="logout">Déconnexion</button></form></code> . Le traitement vérifie <code>\$_POST['logout']</code> .
Statut	✅ Résolu

● INC-005 — Aucun contrôle de chevauchement horaire des cours

Sévérité	● Majeur (cohérence métier)
Composant	<code>Modele::insert_cours()</code> / <code>update_cours()</code>
Symptôme	Possibilité de créer 2 cours simultanés pour le même candidat, ou le même moniteur, ou le même véhicule. Violation de la règle RG2 du CDC.
Cause	Pas de vérification avant l'INSERT.
Correction	Implémentation de la méthode <code>verifierConflitHoraire()</code> qui vérifie l'absence de chevauchement pour le candidat, le moniteur ET le véhicule à la date et plage horaire demandées. Exception levée avec message explicite si conflit.
Statut	✅ Résolu

● INC-006 — Planification possible avec véhicule en réparation

Sévérité	● Majeur (cohérence métier)
Composant	Modele::insert_cours()
Symptôme	Aucune vérification de l'état du véhicule. On pouvait planifier un cours avec un véhicule au statut <code>En réparation</code> ou <code>Indisponible</code> .
Cause	Pas de pré-check sur l'état du véhicule avant insertion.
Correction	Ajout de la méthode <code>vehiculeEstDisponible()</code> qui vérifie que <code>etat = 'Disponible'</code> . Exception levée avec message clair sinon.
Statut	✅ Résolu

● INC-007 — Page 51 référencée mais vue inexistante

Sévérité	● Mineur (code mort)
Composant	<code>index.php</code>
Symptôme	La route <code>?page=51</code> (véhicules candidat) appelait un fichier <code>vue/candidat/vue_vehicules_candidat.php</code> qui n'existait pas → erreur PHP fatale si appelé directement.
Cause	Code mort laissé par une itération précédente. La fonctionnalité est déjà couverte par la page <code>?page=3</code> (flotte publique filtrée sur état <code>Disponible</code>).
Correction	Suppression de la route inutile.
Statut	✅ Résolu

● INC-008 — Moniteur sans accès aux véhicules / candidats

Sévérité	● Mineur (ergonomie)
Composant	Menu moniteur (<code>vue/entete.php</code>) + nouvelles vues
Symptôme	Le moniteur connecté n'avait que « Mon Planning ». Il ne pouvait pas savoir quels véhicules étaient disponibles ni qui étaient ses candidats.
Cause	Périmètre fonctionnel initial trop restreint.
Correction	Ajout de 3 nouvelles pages pour le rôle moniteur : « Mes Candidats » (avec statistiques), « Véhicules » (liste complète avec état), « Mon Profil » (modification de ses infos).
Statut	✅ Résolu

● INC-009 — Moniteur ne pouvait pas marquer un cours effectué/annulé

Sévérité	● Mineur (ergonomie)
Composant	vue/moniteur/vue_planning_moniteur.php
Symptôme	Le moniteur voyait son planning mais ne pouvait pas indiquer qu'un cours était terminé ou qu'il avait dû l'annuler. Seul l'admin avait ces actions.
Cause	Aucun bouton d'action sur la vue moniteur.
Correction	Ajout de boutons « Valider » (passe le cours en <code>Effectué</code>) et « Annuler » (passe en <code>Annulé</code>) sur chaque cours à venir. Côté serveur, méthode <code>update_statut_cours_moniteur()</code> qui vérifie que le cours appartient bien au moniteur connecté (sécurité).
Statut	✅ Résolu

● INC-010 — Candidat et moniteur ne pouvaient pas modifier leur profil

Sévérité	● Mineur
Composant	Vues candidat + moniteur
Symptôme	Le candidat (sauf à la première connexion) et le moniteur ne pouvaient pas mettre à jour leur tél, leur adresse ou leur email.
Cause	Aucune route ni vue dédiée à la modification du profil hors admin.
Correction	Création des pages « Mon Profil » (pages 53 et 63) avec mode lecture par défaut + bouton « Modifier ». Validation côté serveur (email valide, etc.).
Statut	✅ Résolu

● INC-011 — Images véhicules ne s'affichaient pas via lien symbolique WAMP

Sévérité	● Cosmétique
Composant	vue/public/flotte.php
Symptôme	Quand le projet est servi via un lien symbolique sous WAMP, le test <code>file_exists(__DIR__ . '/...')</code> retournait <code>false</code> à tort → affichage de l'image SVG par défaut au lieu de la vraie photo.
Cause	Mauvaise interaction entre <code>__DIR__</code> PHP et les liens symboliques Apache Windows.
Correction	Suppression du test <code>file_exists</code> et utilisation de l'attribut HTML <code>onerror</code> pour basculer sur l'image par défaut si le navigateur ne charge pas l'image.
Statut	✅ Résolu

● INC-012 — Bouton « Déconnexion » mal aligné dans le menu

Sévérité	● Cosmétique
Composant	design/style.css
Symptôme	Après migration en formulaire POST, le bouton apparaissait avec un fond bleu, prenait toute la largeur disponible et était décalé verticalement par rapport aux autres liens du menu.
Cause	Règle globale <code>input[type="submit"], button[type="submit"]</code> qui imposait <code>width: 100%</code> et <code>margin-top: 10px</code> .
Correction	Override CSS sur la classe <code>.nav-logout</code> avec <code>!important</code> pour réinitialiser largeur et marges, et appliquer le style identique au bouton « Connexion » du menu visiteur.
Statut	✅ Résolu

3. Synthèse — Client léger PHP

Niveau	Nombre	Résolu
● Critique	1	1 documenté pour v2
● Majeur	4	4 résolus
● Mineur	4	4 résolus
● Cosmétique	2	2 résolus
Total	11	10 résolus + 1 planifié v2

4. Démarche d'amélioration continue (v2)

Pour la prochaine itération, l'équipe vIndkaizen prévoit :

1. **Hashage des mots de passe** avec `password_hash()` (bcrypt)
2. **Protection CSRF complète** sur tous les formulaires sensibles (token aléatoire en session)
3. **Politique MDP renforcée** : 12 caractères + caractère spécial obligatoire (recommandation CNIL renforcée)
4. **Système de notifications email** pour les changements de cours
5. **Demande de cours côté candidat** + validation par le moniteur ou l'admin
6. **Statistiques admin** : nb cours par moniteur, taux de remplissage, taux de réussite